

Bachelor in Computer Engineering — Management and Information Systems

Ethical Pentesting in Virtualized Environments with EVE-NG

Lab 3

Incident Response & Log Forensics

Teacher Reference — Do Not Distribute

Do not distribute to students.
This document contains the complete solution including flags and
credentials.

Techniques	Brute force, sudo privesc, persistence, lateral movement
MITRE	TA0001, TA0004, TA0003, TA0008, TA0010
Max points	20

Eloi Egea Rada
Supervisor: Pere Vidiella i Catalan

Task 1 — Initial Access on helix-web (3 points)

Attacker IP: 185.220.101.47

Targeted user: devops

Successful login time: 03:17:42

Key log lines:

```
Apr 24 03:05:03 helix-web sshd[1201]: Failed password for devops
    from 185.220.101.47 port 42001 ssh2
... (25 total failures)
Apr 24 03:17:42 helix-web sshd[1231]: Accepted password for devops
    from 185.220.101.47 port 43100 ssh2
```

Commands expected from the student:

```
grep "Failed_password\|Accepted_password" /var/log/auth.log
grep 'Failed_password_for_devops' /var/log/auth.log | wc -l
# 25
```

Task 2 — Privilege Escalation (4 points)

Command used: sudo /usr/bin/find

Misconfiguration: /etc/sudoers.d/devops contains NOPASSWD:
/usr/bin/find

MITRE technique: T1548.003 — Abuse Elevation Control Mechanism:
Sudo and Sudo Caching

Prevention: Remove NOPASSWD; apply principle of least privilege;
use visudo

Key log lines:

```
Apr 24 03:18:01 helix-web sudo: devops : TTY=pts/0 ;
    PWD=/home/devops ; USER=root ; COMMAND=/usr/bin/find
```

```
# /etc/sudoers.d/devops
devops ALL=(ALL) NOPASSWD: /usr/bin/find
```

GTFOBins vector: find's -exec flag executes arbitrary commands as root.

```
sudo find / -name "*.conf" -exec cat {} \;
```

Task 3 — Persistence & Post-Exploitation (3 points)

Backdoor account: maint (UID 1003)

Privileges: NOPASSWD: ALL via /etc/sudoers.d/maint

Key log lines:

```
Apr 24 03:19:15 helix-web useradd[2041]: new user: name=maint,  
UID=1003, GID=1003, home=/home/maint, shell=/bin/bash
```

Full attacker command history (/home/devops/.bash_history):

```
id  
whoami  
sudo /usr/bin/find / -name "*.conf" -exec cat {} \;  
useradd -m maint  
echo "maint ALL=(ALL) NOPASSWD: ALL" > /etc/sudoers.d/maint  
chmod 440 /etc/sudoers.d/maint  
exit
```

Task 4 — Lateral Movement to helix-db (3 points)

Source IP: 192.168.50.10 (helix-web internal IP)

User: devops (same compromised credentials — password reuse)

Time: 03:21:03

Key log line on helix-db:

```
Apr 24 03:21:03 helix-db sshd[987]: Accepted password for devops  
from 192.168.50.10 port 51234 ssh2
```

```
# Student pivot from helix-web:  
ssh analyst@192.168.60.10 # Analyst2024  
grep 'Accepted' /var/log/auth.log
```

Task 5 — Data Exfiltration Evidence (3 points)

Sensitive data: /opt/helix/data/clients.db (SQLite with fictional client records)

Evidence: /opt/helix/data/.exfil_marker

```
185.220.101.47 - 2026-04-24 03:22 - data accessed
```

The external IP matches the initial brute-force source. Timestamp 03:22 follows the lateral movement login at 03:21.

Task 6 — Incident Report (4 points)

Indicators of Compromise (IOCs)

- **IP:** 185.220.101.47 (external attacker)
- **User:** devops (compromised via brute force)

- **Backdoor:** `maint` account (UID 1003, NOPASSWD: ALL)
- **Files:** `/opt/helix/data/clients.db`, `.exfil_marker`
- **Technique:** `GTFOBins sudo find (T1548.003)`

Complete attack timeline

Time	Host	Event
03:05–03:16	helix-web	25 failed SSH attempts for devops from 185.220.101.47
03:17	helix-web	Successful login as devops
03:18	helix-web	Privilege escalation via <code>sudo find</code>
03:19	helix-web	Backdoor account <code>maint</code> created
03:21	helix-db	Lateral movement from 192.168.50.10
03:22	helix-db	Access to <code>clients.db</code> + <code>.exfil_marker</code> created

Recommended remediation

1. Disable `devops` and `maint` accounts immediately
2. Remove NOPASSWD from `/etc/sudoers.d/devops`
3. Rotate all credentials on both servers
4. Implement SSH key-based auth; disable password authentication
5. Deploy `fail2ban` + `auditd` on all servers
6. Apply least-privilege ownership on `/opt/helix/data/`